

AEGIS-API

Unified API Security Assessment Report

Assessment Date: 2026-05-27 17:47:39

Protocols Tested: Rest

Rest: <http://127.0.0.1:8888>

CONFIDENTIAL — For authorized recipient only. Do not distribute without permission.

SECTION 1 — EXECUTIVE SUMMARY

Aegis-API completed a unified API security assessment covering **Rest** API protocols. A total of **3 vulnerabilities** were identified. The overall risk rating for this assessment is: **High**.

Vulnerability Distribution by Severity

Severity	Count	Risk Level
Critical	0	Immediate action required
High	1	Fix within sprint
Medium	0	Fix within quarter
Low	0	Best effort
Info	2	Informational

Vulnerability Distribution by Protocol

Protocol	Findings	Target URL
Rest	0	http://127.0.0.1:8888

Key Recommendations

- [High] Remediate **Insecure Direct Object Reference (IDOR)** in the REST layer — maps to UNKNOWN: Unknown.

SECTION 2 — SCOPE AND METHODOLOGY

Assessment Date: 2026-05-27 17:47:39

Target Scope

Protocol	Target URL	Discovery Method
Rest	http://127.0.0.1:8888	Manual

Testing Methodology by Protocol

OWASP API Top 10 Coverage Matrix

OWASP ID	Category	REST	SOAP	GraphQL
API1	Broken Object Level Authorization (BOLA/...	✓ IDOR/BOLA	—	✓ Field auth
API2	Broken Authentication...	✓ JWT	✓ WS-Security	✓ JWT
API3	Broken Object Property Level Authorizati...	✓ Mass Assignment	—	✓ Mutation inject
API4	Unrestricted Resource Consumption...	✓ Rate limit	—	✓ Depth + Batch
API7	Server Side Request Forgery...	—	✓ XXE/SSRF	—
API8	Security Misconfiguration...	—	✓ WSDL exposure	✓ Introspection

SECTION 3 — DETAILED FINDINGS

Finding 1: Insecure Direct Object Reference (IDOR)

Protocol	REST	Severity	High
OWASP ID	UNKNOWN	OWASP Category	Unknown
CVSS Score	8.1	CVSS Justification	

Description

The API endpoint returns the same resource data to both authenticated and unauthenticated requests. This indicates the server is not enforcing object-level authorization checks.

Remediation

Implement object-level authorization checks on every API endpoint. Verify that the requesting user owns or has permission to access the requested resource before returning data. Never rely solely on the client to restrict which IDs are requested.

Finding 2: alg:none Bypass Token Generated

Protocol	REST	Severity	Info
OWASP ID	UNKNOWN	OWASP Category	Unknown
CVSS Score	N/A	CVSS Justification	

Description

Remediation

Finding 3: No Rate Limiting Detected (OWASP API4)

Protocol	REST	Severity	Info
OWASP ID	UNKNOWN	OWASP Category	Unknown
CVSS Score	N/A	CVSS Justification	

Description

Remediation

SECTION 4 — REMEDIATION SUMMARY TABLE

#	Finding	Protocol	Severity	OWASP	Fix Effort	Priority
1	Insecure Direct Object Reference (I	REST	High	UNKNOWN	Short-term (< 1 week)	P2
2	alg:none Bypass Token Generated	REST	Info	UNKNOWN	Optional	P4
3	No Rate Limiting Detected (OWASP AP	REST	Info	UNKNOWN	Optional	P4

SECTION 5 — APPENDIX

A — Tool Configuration

```
target: http://127.0.0.1:8888
protocol: auto
proxy: disabled
auth_provided: True
wordlist: default
params: default
```

B — Raw Audit Log (last 50 entries)

Type: alg:none Bypass Token Generated

Protocol: REST

OWASP: API2:2023

URL: http://127.0.0.1:8888

Status: N/A

Evidence:

```
{
  "detail": "A forged token with alg='none' was constructed from this token's payload. Submit it to an a
  "severity": "High",
  "remediation": "Explicitly configure your JWT library to reject alg='none'. Example in PyJWT: jwt.deco
  "raw": "Forged token (first 120 chars): eyJhbGciOiJub251IiwidHlwIjoiSldUIn0.eyJzdWIiOiJhQG6IuY29tIiwiaW
}
```

Type: Insecure Direct Object Reference (IDOR)

Protocol: REST

OWASP: API1:2023 - Broken Object Level Authorization

URL: N/A

Status: N/A

Evidence:

```
{
  "url": "http://127.0.0.1:8888/workshop/api/shop/orders/2",
  "similarity_ratio": 1.0,
  "auth_status_code": 200,
  "unauth_status_code": 200,
  "auth_response_preview": "{\"order\":{\"id\":2,\"user\":{\"email\":\"pogba006@example.com\",\"number\"
  "unauth_response_preview": "{\"order\":{\"id\":2,\"user\":{\"email\":\"pogba006@example.com\",\"number
}
```

Type: rate_limit

Protocol: REST

OWASP: API4:2023

URL: http://127.0.0.1:8888/identity/api/auth/login

Status: N/A

Evidence:

```
{
  "detail": "The endpoint http://127.0.0.1:8888/identity/api/auth/login returned no HTTP 429 response a",
  "severity": "High",
  "remediation": "Implement server-side rate limiting on all authentication and sensitive action endpoi",
  "raw": "Sent 50 requests | Success responses: 0 | 429 responses: 0 | Avg response time: 29ms",
  "pattern": "none",
  "threshold": null,
  "burst_count": 50
}
```

C — References

- OWASP API Security Top 10 (2023): <https://owasp.org/API-Security/>
- CVSS v3.1 Calculator: <https://www.first.org/cvss/calculator/3.1>
- crAPI Vulnerable REST Lab: <https://github.com/OWASP/crAPI>
- DVGA Vulnerable GraphQL Lab: <https://github.com/dolevf/Damn-Vulnerable-GraphQL-Application>
- WebGoat SOAP Lab: <https://github.com/WebGoat/WebGoat>
- JWT Security Best Practices:
https://cheatsheetseries.owasp.org/cheatsheets/JSON_Web_Token_Cheat_Sheet.html
- XXE Prevention:
https://cheatsheetseries.owasp.org/cheatsheets/XML_External_Entity_Prevention_Cheat_Sheet.html